

**PANEVROPSKI UNIVERZITET APEIRON, BANJA LUKA
FAKULTET INFORMACIONIH TEHNOLOGIJA**

**Redovne studije
Smjer : “Inženjering Informacionih Tehnologija“**

**Predmet:
Konkurentno računarstvo-distribuirano programiranje**

**BEZBJEDNOST U DISTRIBUIRANIM
SISTEMIMA: IZAZOVI I RJEŠENJA
(Seminarski rad)**

**Predmetni nastavnik
Prof. dr Negovan Stamenković**

**Student: Ivan Pavlović
Br. Indeksa: 92-20-RITP-S**

Banja Luka, april 2026

SADRŽAJ

UVOD	1
1. OSNOVE DISTRIBUIRANIH SISTEMA I BEZBJEDNOSTI.....	2
1.1. Pojam distribuiranih sistema.....	2
1.2. Pojam bezbjednosti informacionih sistema	3
1.2.1. Povjerljivost, integritet i dostupnost	4
1.2.2. Autentifikacija, autorizacija i odgovornost.....	4
1.3. Specifičnosti bezbjednosti u distribuiranim sistemima.....	5
2. PRIJETNJE I RANJIVOSTI U DISTRIBUIRANIM SISTEMIMA.....	6
2.1. Mrežne prijetnje i neovlašćeni pristup.....	6
2.2. Napadi na identitet i mehanizme prijave	7
2.2.1. Krađa akreditiva i zloupotreba naloga	7
2.2.2. Eskalacija privilegija i bočno kretanje kroz sistem.....	8
2.3. Napadi na podatke i komunikacione tokove	8
2.4. Napadi na dostupnost servisa i resursa	9
2.5. Greške konfiguracije i ljudski faktor kao bezbjednosni problem	9
3. KLJUČNI ZAHTJEVI I PRINCIPI BEZBJEDNOSTI U DISTRIBUIRANIM SISTEMIMA	11
3.1. Očuvanje povjerljivosti podataka	11
3.2. Očuvanje integriteta sistema i informacija	11
3.3. Obezbjedenje dostupnosti i otpornosti sistema.....	12
3.4. Upravljanje identitetom i kontrola pristupa	12
3.5. Praćenje aktivnosti, revizija i odgovornost korisnika	13
4. TEHNIKE I RJEŠENJA ZA ZAŠTITU DISTRIBUIRANIH SISTEMA.....	14
4.1. Kriptografija i zaštita podataka.....	14
4.2. Digitalni sertifikati, PKI i bezbjedni komunikacioni protokoli	15
4.3. Autentifikacija korisnika i višefaktorska zaštita	15
4.4. Modeli autorizacije i upravljanje privilegijama.....	16
4.5. Segmentacija mreže, izolacija servisa i zaštitni mehanizmi	17
4.6. Evidencija događaja, nadzor i odgovor na incidente	17
5. BEZBJEDNOST U SAVREMENIM ARHITEKTURAMA DISTRIBUIRANIH SISTEMA	19
5.1. Bezbjednost cloud okruženja	19
5.2. Bezbjednost mikroservisnih arhitektura	19

5.3.	Bezbjednost API interfejsa i servisne komunikacije	20
5.4.	Bezbjednost kontejnera i orkestracionih platformi	21
6.	IZAZOVI IMPLEMENTACIJE BEZBJEDNOSTI U DISTRIBUIRANIM SISTEMIMA	22
6.1.	Složenost infrastrukture i veliki broj komponenti	22
6.2.	Balans između performansi i bezbjednosti	22
6.3.	Upravljanje tajnama, ključevima i sertifikatima	23
6.4.	Usaglašenost sa propisima i zaštita privatnosti.....	23
6.5.	Održavanje, nadzor i forenzička analiza u distribuiranom okruženju	24
7.	NAJBOLJE PRAKSE I PREPORUKE ZA UNAPREĐENJE BEZBJEDNOSTI.....	25
7.1.	Ugradnja bezbjednosti od faze projektovanja sistema.....	25
7.2.	Primjena principa najmanjih privilegija i nultog povjerenja	25
7.3.	Redovno ažuriranje, testiranje i procjena rizika	26
7.4.	Automatizacija bezbjednosnih provjera i DevSecOps pristup.....	26
7.5.	Edukacija korisnika i razvoj bezbjednosne kulture	27
ZAKLJUČAK		28
POPIS SLIKA		29
CITATNI IZVORI		30

UVOD

Distribuirani sistemi zauzimaju centralno mjesto u savremenom računarstvu i predstavljaju osnovu velikog broja aplikacija i servisa koji se danas svakodnevno koriste. Gotovo svaki značajan informacioni sistem, od web aplikacija i cloud platformi, preko poslovnih informacionih rješenja, pa sve do mobilnih servisa, društvenih mreža, internet bankarstva i industrijskih sistema, na neki način funkcioniše kao distribuirano okruženje. U takvom modelu rada više međusobno povezanih računara, servera, usluga i mrežnih čvorova zajednički obavlja određene funkcije, pri čemu korisniku sistem često djeluje kao jedna objedinjena cjelina. Upravo ta raspodjela poslova, podataka i funkcionalnosti omogućava visoku skalabilnost, fleksibilnost i dostupnost, ali istovremeno uvodi i ozbiljne bezbjednosne izazove.

Za razliku od centralizovanih sistema, distribuirani sistemi imaju više komunikacionih tačaka, više procesa razmjene podataka i više komponenti koje moraju biti međusobno usklađene i zaštićene. Podaci u takvim sistemima ne nalaze se nužno na jednom mjestu, već mogu biti raspoređeni kroz više mrežnih lokacija, različitih servera, servisa, baza podataka i aplikacionih slojeva. To znači da površina napada postaje znatno veća, a mogućnosti za zloupotrebu brojnije. Napadač više ne mora probiti samo jednu ulaznu tačku sistema, već može pokušati iskoristiti pogrešno podešen servis, nezaštićen API interfejs, ukradeni korisnički identitet, loše upravljane privilegije ili ranjivost u komunikaciji između komponenti.

Bezbjednost u distribuiranim sistemima zato se ne može posmatrati kao dodatna funkcionalnost koja se uvodi tek nakon razvoja aplikacije. Ona mora biti sastavni dio arhitekture, mrežnog dizajna, upravljanja identitetima, zaštite komunikacije i upravljanja podacima. U praksi to znači da se bezbjednosni mehanizmi moraju planirati od samog početka, kroz izbor odgovarajućih protokola, modela autentifikacije, autorizacionih pravila, kriptografskih rješenja, načina segmentacije mreže i pristupa nadzoru sistema. Ako se bezbjednost zanemari ili se uvede površno, cijeli distribuirani sistem može postati izuzetno ranjiv, čak i kada su njegove funkcionalne i performansne osobine zadovoljavajuće.

Dodatni problem predstavlja činjenica da savremeni distribuirani sistemi više nijesu ograničeni samo na tradicionalne serverske mreže. Danas su u upotrebi cloud infrastrukture, mikroservisne arhitekture, kontejnerska okruženja, edge sistemi i uređaji interneta stvari, što dodatno povećava složenost bezbjednosnog upravljanja. U takvim okruženjima administrator i projektant ne brinu samo o zaštiti jedne aplikacije ili jednog servera, već o zaštiti čitavog ekosistema usluga koje se neprekidno pokreću, zaustavljaju, umrežavaju i razmjenjuju podatke. Svaka nova komponenta, svaki novi servis i svaka nova integracija uvode dodatni rizik i potrebu za pažljivom kontrolom.

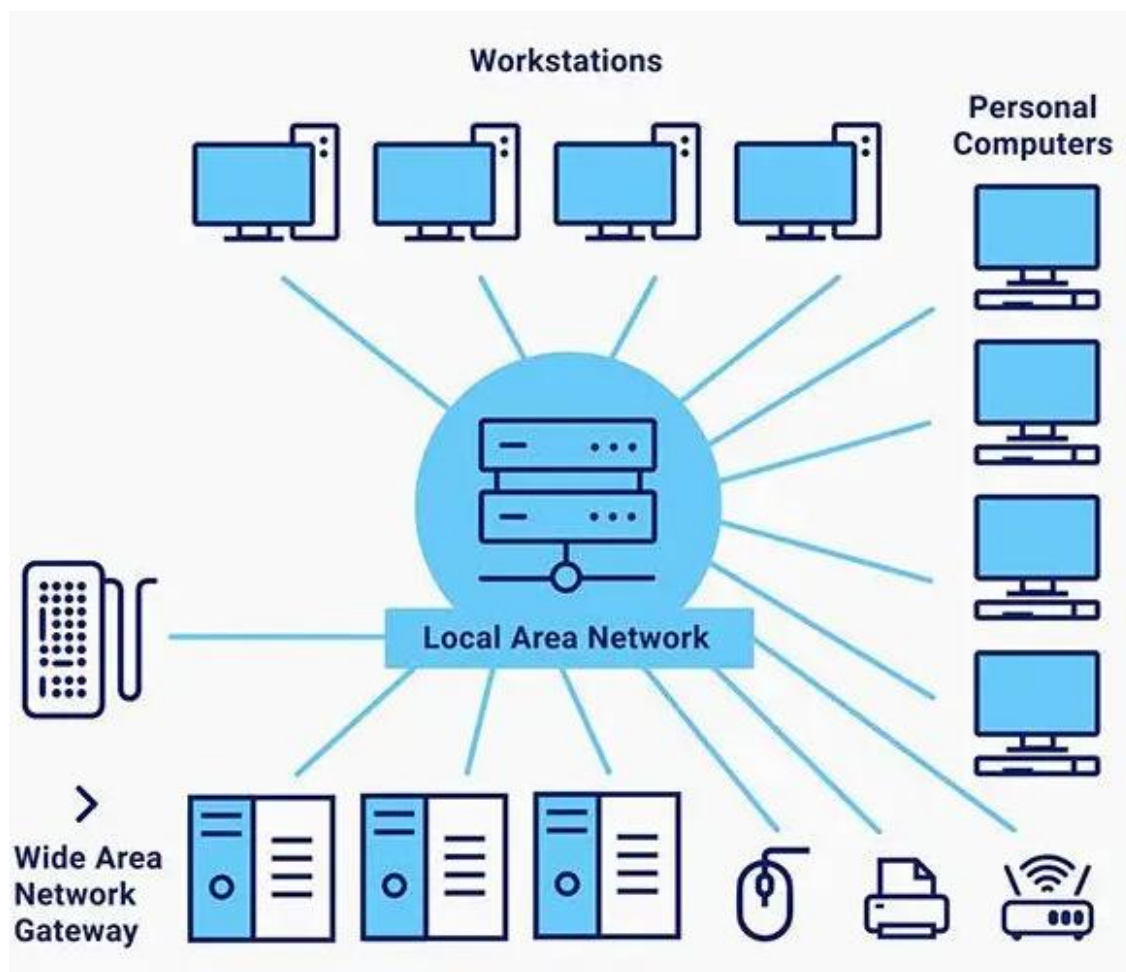
Cilj ovog seminarskog rada jeste da prikaže osnovne izazove bezbjednosti u distribuiranim sistemima i da analizira najvažnija rješenja koja se koriste za njihovu zaštitu. Rad će najprije objasniti osnovne pojmove distribuiranih sistema i bezbjednosti, zatim predstaviti najčešće prijetnje i ranjivosti, a potom razmotriti ključne principe zaštite, tehnička rješenja, savremene arhitektonske izazove i preporučene prakse. Posebna pažnja biće posvećena zaštiti podataka, upravljanju identitetom, bezbjednoj komunikaciji, otpornosti sistema na napade i ulozi organizacionih mjera u očuvanju bezbjednosti. Na kraju rada biće izveden zaključak o značaju sistemskog i višeslojnog pristupa bezbjednosti u savremenim distribuiranim okruženjima.

1. OSNOVE DISTRIBUIRANIH SISTEMA I BEZBJEDNOSTI

1.1. Pojam distribuiranih sistema

Distribuirani sistem može se opisati kao skup međusobno povezanih računarskih jedinica koje sarađuju putem mreže i zajednički ostvaruju određenu funkcionalnost. Te jedinice mogu biti serveri, radne stanice, virtualne mašine, kontejneri, mrežni servisi, baze podataka ili uređaji sa posebnim funkcijama, a korisniku se u idealnom slučaju predstavljaju kao jedinstven i funkcionalno usklađen sistem. Osnovna ideja distribuiranog modela jeste da se poslovi i resursi rasporede između više čvorova, čime se povećavaju performanse, skalabilnost i dostupnost.

„U tradicionalnim centralizovanim sistemima glavnina obrade i skladištenja podataka odvijala se na jednom mjestu ili u okviru malog broja čvrsto kontrolisanih računara. Kod distribuiranih sistema takva centralizacija se smanjuje ili u potpunosti napušta. Obrada podataka može biti raspoređena između više čvorova, jedan dio sistema može biti zadužen za komunikaciju sa korisnicima, drugi za poslovnu logiku, treći za čuvanje podataka, a četvrti za međusobnu sinhronizaciju i analitiku. Ovakav pristup omogućava bolju raspodjelu opterećenja i lakše proširenje sistema kako raste broj korisnika ili količina podataka“ [1].



Slika 1 - Dijagram koji prikazuje više servera, baza podataka i klijenata povezanih mrežom

Međutim, upravo ta raspodjela odgovornosti i podataka predstavlja izvor složenosti. Kada više komponenti mora neprekidno komunicirati, razmjenjivati informacije i oslanjati se jedna na drugu, sistem postaje zavisen od mrežnih veza, sinhronizacije i pravilne koordinacije. To znači da kvar, kašnjenje ili kompromitacija jedne komponente mogu uticati i na rad drugih dijelova sistema. U sigurnosnom smislu to dodatno komplikuje zaštitu, jer se više ne štiti jedan zatvoreni i lokalno definisani prostor, već razgranata cjelina sa većim brojem ulaznih i komunikacionih tačaka.

„Distribuirani sistemi su posebno važni u savremenim poslovnim, internet i cloud okruženjima zato što omogućavaju prilagođavanje promjenljivim zahtjevima. Rast broja korisnika, povećanje obima podataka i potreba za neprekidnom dostupnošću servisa gotovo su natjerali savremene organizacije da pređu sa manjih, zatvorenih sistema na raspodijeljene i mrežno zasnovane arhitekture“ [2]. Takav razvoj donio je veliku funkcionalnu korist, ali je istovremeno od bezbjednosti napravio jedan od najvažnijih arhitektonskih problema.

1.2. Pojam bezbjednosti informacionih sistema

„Bezbjednost informacionih sistema predstavlja skup principa, pravila, tehnologija i postupaka kojima se štite podaci, aplikacije, mreže, korisnici i resursi od neovlašćenog pristupa, zloupotrebe, izmjene, uništavanja ili prekida rada. U najširem smislu, cilj bezbjednosti nije samo spriječiti napad, već očuvati pouzdanost, kontinuitet i vjerodostojnost rada sistema“ [1]. Drugim riječima, bezbjednost se ne odnosi samo na odbranu od spoljnog napadača, već i na očuvanje ispravnog funkcionisanja sistema uprkos greškama, zloupotrebama, internim propustima i incidentima.

U praksi se bezbjednost dugo tumačila kroz zaštitu hardvera i lokalnih računarskih resursa, ali savremeni informacioni sistemi zahtijevaju mnogo širi pogled. Danas se štite digitalni identiteti, komunikacioni tokovi, aplikacioni interfejsi, baze podataka, servisi u oblaku, mobilni uređaji, programske zavisnosti i automatizovani procesi. Zato bezbjednost obuhvata i tehničke i organizacione mjere. Nije dovoljno imati jak algoritam za šifrovanje ako su korisničke privilegije loše podešene, ako su lozinke slabe, ako se incidenti ne prijavljuju ili ako ne postoji jasna politika pristupa podacima.

„Poseban značaj bezbjednosti u distribuiranim sistemima proizlazi iz činjenice da se napadi mogu odvijati na više nivoa istovremeno. Napadač može pokušati da presretne mrežnu komunikaciju, da kompromituje korisnički nalog, da iskoristi grešku u servisu, da pristupi nedovoljno zaštićenoj bazi podataka ili da izazove prekid rada preopterećenjem sistema“ [1]. Zbog toga se bezbjednost ne smije svesti samo na jedan sloj odbrane. Ona mora biti višeslojna, dosljedna i povezana sa svakim dijelom arhitekture.

U savremenom okruženju bezbjednost je i pitanje povjerenja. „Korisnik koristi sistem pod pretpostavkom da su njegovi podaci zaštićeni, da pristup neće dobiti neovlašćene osobe i da će servis biti dostupan kada mu je potreban. Organizacije grade reputaciju upravo na osnovu toga koliko mogu očuvati to povjerenje“ [2]. Zbog toga bezbjednost više nije samo tehnički zadatak administratora, već strateško pitanje upravljanja i kvaliteta informacionog sistema.

1.2.1. Povjerljivost, integritet i dostupnost

Tri klasična stuba bezbjednosti informacionih sistema predstavljaju povjerljivost, integritet i dostupnost. Povjerljivost podrazumijeva da informacije budu dostupne samo onim korisnicima, procesima i servisima koji imaju legitimno pravo pristupa. U distribuiranim sistemima povjerljivost se mora štititi ne samo u bazama podataka, već i tokom prenosa podataka između čvorova, tokom međuservisne komunikacije i kroz pravilno definisane politike pristupa.

„Integritet označava očuvanje tačnosti, potpunosti i neizmijenjenosti podataka i sistema. Ako napadač ili greška izmijene sadržaj podataka, ako dođe do neprimijećene manipulacije ili ako više komponenti sistema vidi različite i međusobno neusklađene verzije iste informacije, integritet je narušen“ [1]. „U distribuiranim sistemima integritet je posebno osjetljiv zbog replikacije podataka, mrežnih kašnjenja i potrebe da više komponenti sinhronizovano koristi iste informacije“ [2].

Dostupnost podrazumijeva da sistem, servis ili podatak budu na raspolaganju ovlašćenim korisnicima kada su potrebni. U mnogim savremenim servisima upravo je dostupnost jednako važna kao i tajnost podataka. Ako sistem elektronskog plaćanja, zdravstveni informacioni sistem ili platforma za poslovnu komunikaciju postanu nedostupni, posljedice mogu biti ozbiljne čak i ako nije došlo do krađe podataka. U distribuiranim sistemima dostupnost zavisi od pouzdanosti mreže, otpornosti komponenti, mogućnosti oporavka i zaštite od napada koji imaju za cilj obustavu rada.

Ova tri principa međusobno su povezana, ali često nijesu potpuno usklađena. Ponekad pojačana bezbjednost utiče na brzinu ili lakoću pristupa, dok insistiranje na visokoj dostupnosti može povećati složenost arhitekture i mogućnost novih ranjivosti. Zbog toga projektovanje bezbjednosti podrazumijeva pronalaženje ravnoteže između zahtjeva sistema, očekivanja korisnika i realnih rizika.

1.2.2. Autentifikacija, autorizacija i odgovornost

Pored tri osnovna stuba bezbjednosti, savremeni sistemi snažno se oslanjaju i na mehanizme autentifikacije, autorizacije i odgovornosti. Autentifikacija predstavlja proces utvrđivanja identiteta korisnika, servisa ili uređaja. Drugim riječima, sistem mora imati način da provjeri da li je entitet koji traži pristup zaista onaj za koga se predstavlja. U distribuiranim sistemima ovo nije ograničeno samo na ljude koji se prijavljuju lozinkom, već i na međusobnu provjeru servisa, aplikacija, automatizovanih agenata i uređaja.

„Autorizacija podrazumijeva određivanje prava pristupa nakon što je identitet provjeren. Nije dovoljno znati ko je korisnik, već i šta mu je dozvoljeno da uradi. U složenim distribuiranim sistemima često postoji više nivoa pristupa, različite uloge, različiti servisi i različiti skupovi privilegija. Ako se autorizacija ne sprovede precizno, može doći do situacije da legitimno prijavljeni korisnik obavlja radnje koje ne bi smio, čime se ugrožava cijeli sistem“ [1].

„Odgovornost ili mogućnost praćenja aktivnosti znači da sistem mora biti sposoban da evidentira ko je i kada izvršio određenu radnju. Ovo je presudno i za bezbjednost i za reviziju, jer bez praćenja događaja nije moguće pouzdano utvrditi uzrok incidenta, tok kompromitacije ili odgovornost

korisnika i servisa“ [2]. U distribuiranim sistemima ovaj aspekt je posebno zahtjevan, pošto jedna akcija korisnika može pokrenuti lanac događaja kroz veći broj servisa i čvorova. Zato su kvalitetno logovanje, korelacija događaja i centralizovano praćenje izuzetno važni.

1.3. Specifičnosti bezbjednosti u distribuiranim sistemima

„Bezbjednost distribuiranih sistema razlikuje se od bezbjednosti manjih lokalnih sistema prije svega zbog raspoređene prirode resursa i komunikacije. U klasičnom zatvorenom sistemu administrator može relativno lako kontrolisati pristup fizičkoj infrastrukturi, lokalnoj mreži i aplikacijama. U distribuiranom sistemu resursi su rasuti, komunikacija se odvija preko različitih mrežnih segmenata, a identiteti i privilegije moraju biti dosljedno sprovedeni kroz više slojeva i servisa.

Jedna od najvećih specifičnosti jeste povećana površina napada. Svaki dodatni servis, svaki API interfejs, svaka mrežna veza i svaki integrisani sistem mogu predstavljati novu potencijalnu tačku ulaza za napadača. U monolitnim sistemima odbrana se često fokusira na nekoliko jasno definisanih granica. U distribuiranim sistemima granica ima mnogo više i one nijesu uvijek fizički ili logički lako uočljive. Zbog toga tradicionalni pristup zasnovan samo na zaštiti perimetra više nije dovoljan“ [1].

Druga specifičnost ogleda se u međuzavisnosti komponenti. Kompromitacija jedne usluge ne mora ostati lokalni problem. Ako taj servis ima povjerenje drugih servisa, pristup zajedničkim tajnama, mrežnu povezanost sa internim segmentima ili veće privilegije nego što je potrebno, napadač može iskoristiti tu početnu tačku za dalje kretanje kroz sistem. Ova pojava poznata je kao bočno kretanje i predstavlja jedan od najozbiljnijih problema u savremenim distribuiranim okruženjima.

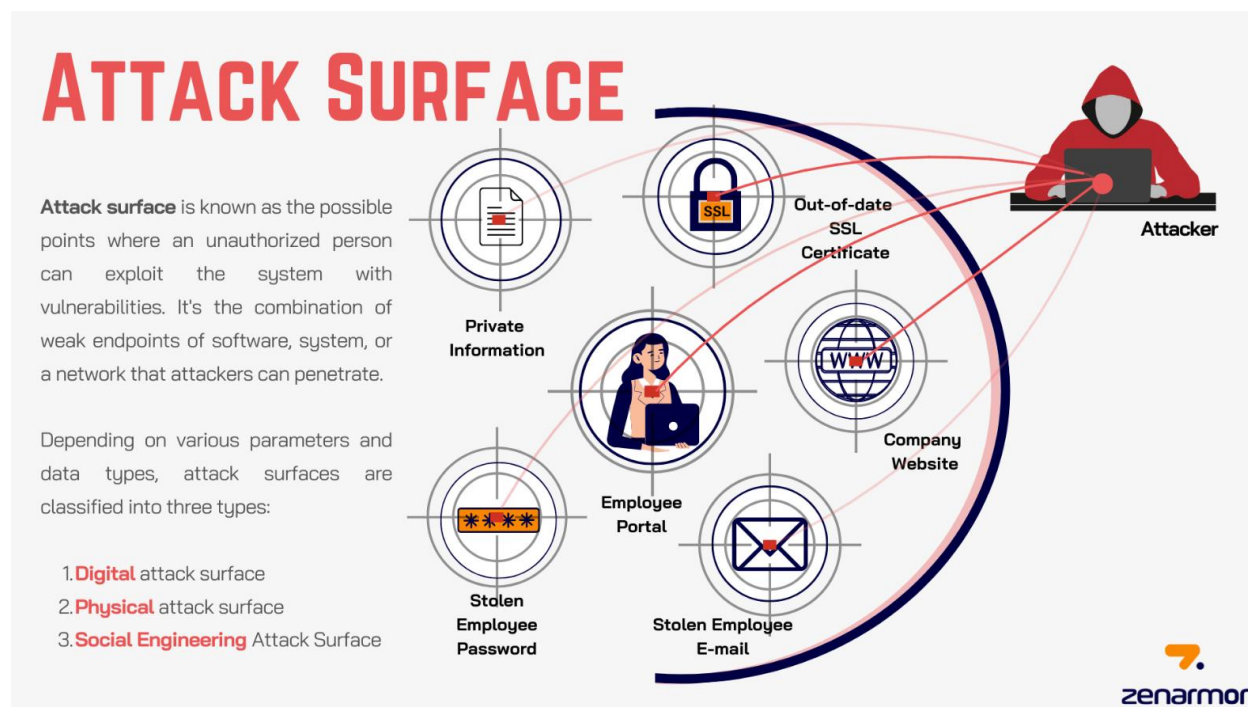
Treća specifičnost je teškoća nadzora i centralnog pregleda nad stanjem sistema. U malim sistemima često je moguće ručno pregledati zapise, konfiguracije i tokove rada. U velikim distribuiranim okruženjima postoji ogroman broj logova, događaja, konekcija i kratkotrajnih instanci servisa. Bez naprednih sistema za nadzor, korelaciju i analizu događaja, organizacija može imati lažan osjećaj sigurnosti, dok se napad u stvarnosti već odvija kroz više komponenti.

Posebnu složenost unosi i činjenica da distribuirani sistemi moraju istovremeno biti i bezbjedni i funkcionalno efikasni. „Ako se zaštita postavi tako da znatno usporava komunikaciju, otežava integraciju ili onemogućava skaliranje, sistem može postati neupotrebljiv za poslovne potrebe“ [1]. Zbog toga se bezbjednost u distribuiranim sistemima uvijek mora graditi kao pažljivo balansiran i arhitektonski promišljen skup mjera, a ne kao niz nepovezanih zabrana i tehničkih zakrpa.

2. PRIJETNJE I RANJIVOSTI U DISTRIBUIRANIM SISTEMIMA

2.1. Mrežne prijetnje i neovlašćeni pristup

Distribuirani sistemi po svojoj prirodi zavise od mreže, a upravo ta zavisnost čini mrežne prijetnje jednim od najvažnijih bezbjednosnih rizika. Svaka komunikacija između klijenata, servera, mikroservisa, baza podataka i pomoćnih servisa odvija se preko određene mrežne infrastrukture. Ako je ta komunikacija nezaštićena, loše segmentisana ili nedovoljno nadzirana, napadač može pokušati presretanje saobraćaja, lažno predstavljanje, skeniranje servisa, iskorišćavanje otvorenih portova ili preusmjeravanje zahtjeva.



Slika 2 - Prikaz najčešćih ulaznih tačaka i vektora napada u distribuiranom okruženju – od mrežnih veza i API interfejsa do kompromitovanih identiteta i ranjivih servisa

„Neovlašćeni pristup ne nastaje uvijek samo kao posljedica “hakovanja” u užem smislu. Često je rezultat slabih lozinki, ponovne upotrebe akreditiva, pogrešno podešenih servisa, pretjerano širokih mrežnih pravila ili prisustva zastarjelih komponenti sa poznatim ranjivostima. U distribuiranim sistemima posebno je opasno to što ulazna tačka ne mora biti ključni dio sistema. Napadač može najprije kompromitovati pomoćni servis, testno okruženje, administrativni interfejs ili manje zaštićen čvor, a zatim iskoristiti stečeni pristup za dalji prodor“ [2].

„Mrežne prijetnje obuhvataju i napade tipa presretanja komunikacije, neovlašćenog mijenjanja podataka tokom prenosa, lažnog usmjeravanja saobraćaja i zloupotrebe DNS i ruting mehanizama. Ako distribuisani sistem ne koristi odgovarajuću enkripciju i međusobnu provjeru identiteta komponenti, napadač može pokušati da uspostavi lažnu komunikaciju sa legitimnim servisima ili da ubaci izmijenjene podatke u tok razmjene informacija“ [1].

Ovakvi rizici pokazuju da mrežna zaštita u distribuiranim sistemima ne može biti svedena samo na klasični zaštitni zid na granici mreže. Potrebna je unutrašnja segmentacija, verifikacija svakog zahtjeva, ograničavanje komunikacije na neophodne tokove i stalno praćenje mrežnih obrazaca ponašanja. U suprotnom, sistem može ostati otvoren za napade koji koriste upravo njegovu međusobnu povezanost kao glavno sredstvo kompromitacije.

2.2. Napadi na identitet i mehanizme prijave

Savremeni distribuirani sistemi u velikoj mjeri počivaju na digitalnim identitetima. Korisnici se prijavljuju u aplikacije, administratori pristupaju upravljačkim alatima, servisi međusobno razmjenjuju tokene i sertifikate, a automatizovani procesi koriste tehničke naloge za izvršavanje zadataka. Zbog toga identitet postaje jedno od najvrjednijih sredstava napadača. Umjesto da direktno ruši kriptografske mehanizme ili pokušava složene tehničke proboje, napadač često pokušava da ukrade ili zloupotrijebi legitimni identitet.

Napadi na identitet mogu se izvoditi kroz phishing, presretanje sesija, krađu tokena, iskorišćavanje loših procedura resetovanja lozinke, napade grubom silom ili kompromitaciju skladišta tajni i konfiguracionih fajlova. U distribuiranim sistemima situacija je još osjetljivija, jer jedan identitet može imati pristup većem broju usluga. „Ako napadač kompromituje nalog sa širokim privilegijama, posljedice mogu biti dalekosežne“ [2].

Problem dodatno raste u okruženjima gdje postoji više izvora identiteta, federacija prijave i različiti modeli pristupa različitim dijelovima infrastrukture. Ako nema centralnog i dosljednog upravljanja identitetom, sistem postaje težak za kontrolu. Mogu nastati „siročad“ nalozi, preširoka prava pristupa, nejasne odgovornosti i neusklađene politike lozinke i tokena. Takve situacije stvaraju bezbjednosne praznine koje napadač može lako iskoristiti.

Zbog toga zaštita identiteta u distribuiranim sistemima zahtijeva mnogo više od same prijavne forme. Potrebni su snažni mehanizmi provjere identiteta, centralizovano upravljanje nalogima, višefaktorska autentifikacija, kratkotrajni tokeni, kontrola sesija i strogo praćenje pokušaja pristupa. U praksi upravo kompromitovani identiteti predstavljaju jedan od najčešćih puteva prodora u složene infrastrukturne sisteme.

2.2.1. Krađa akreditiva i zloupotreba naloga

Krađa akreditiva podrazumijeva neovlašćeno pribavljanje podataka za prijavu, kao što su lozinke, tokeni, API ključevi, privatni ključevi, sertifikati ili sesijski identifikatori. U tradicionalnim sistemima krađa lozinke bila je ozbiljan problem, ali je u distribuiranim okruženjima opasnost još veća zato što jedan skup akreditiva može otvoriti pristup većem broju resursa i servisa. Posebno su osjetljivi tehnički nalozi koji služe za međuservisnu komunikaciju, jer često rade u pozadini i imaju šira prava nego što ih imaju obični korisnici.

Zloupotreba naloga ne mora nužno značiti da je identitet ukraden spolja. Često su problem i interni nalozi koji imaju prevelika prava, nalozi bivših zaposlenih koji nijesu deaktivirani, dijeljeni administrativni nalozi ili tehnički nalozi čije se lozinke nikada ne mijenjaju. U takvom okruženju

teško je utvrditi ko je zaista izvršio određenu radnju, a kompromitacija jednog naloga može ostati neprimijećena tokom dužeg perioda.

„Poseban rizik predstavlja čuvanje akreditiva na nebezbjednim mjestima, kao što su tekstualni fajlovi, skripte, konfiguracije bez zaštite ili repozitorijumi izvornog koda. Kada distribuirani sistem ima veliki broj servisa i automatizovanih procesa, iskušenje da se tajne “privremeno” hardkodiraju ili sačuvaju na neadekvatan način postaje veće“ [2]. To često vodi do ozbiljnih incidenata, naročito kada takav kod dospije u javni ili šire dostupan repozitorijum.

Zato su bezbjedno skladištenje i upravljanje akreditivima jedan od temelja zaštite distribuiranih sistema. Bez toga i najjača mrežna zaštita može biti obesmišljena, jer napadač jednostavno koristi legitimne pristupne podatke i time izbjegava dio odbrambenih mehanizama.

2.2.2. Eskalacija privilegija i bočno kretanje kroz sistem

Eskalacija privilegija označava situaciju u kojoj korisnik ili proces dobija viši nivo prava nego što mu je prvobitno dodijeljen. To može biti posljedica pogrešne konfiguracije, ranjivosti u aplikaciji, lošeg modela kontrole pristupa ili iskorišćenih administratorskih grešaka. U distribuiranim sistemima eskalacija privilegija je naročito opasna zato što visokoprivilegovani identiteti često imaju pristup većem broju resursa, uključujući interne mrežne segmente, baze podataka, sisteme za orkestraciju i skladišta tajni.

Bočno kretanje označava napredovanje napadača kroz sistem nakon početne kompromitacije. Napadač najprije dobije pristup jednoj komponenti, a zatim ispituje povjerenje, mrežne veze i privilegije koje mu omogućavaju prelazak na druge servise i čvorove. U distribuiranim sistemima ovo je posebno čest obrazac, jer servisi moraju međusobno sarađivati, a administratori često ostave više komunikacionih puteva otvorenim nego što je neophodno.

Ovaj problem je dodatno izražen u okruženjima gdje nema stroge segmentacije mreže i gdje se jednom provjerenom servisu automatski vjeruje u komunikaciji sa drugim servisima. Ako napadač kompromituje jednu instancu, može pokušati da se predstavi kao legitimna interna komponenta i time nastavi napad dublje u infrastrukturu. Upravo zato savremeni bezbjednosni modeli sve više napuštaju pretpostavku da je “unutrašnja mreža sama po sebi bezbjedna”.

Eskalacija privilegija i bočno kretanje često su razlog zbog kojeg manji bezbjednosni propust preraste u veliki incident. Zbog toga je važno ograničiti privilegije svakom entitetu na najmanji neophodan obim, pratiti neobične obrasce pristupa i osigurati da kompromitacija jedne komponente ne znači automatski kompromitaciju cijelog sistema.

2.3. Napadi na podatke i komunikacione tokove

Podaci predstavljaju najvrjedniju imovinu većine informacionih sistema, pa je logično da su i jedan od glavnih ciljeva napadača. U distribuiranim sistemima podaci se nalaze u više oblika i faza. Oni mogu biti trajno sačuvani u bazama podataka, privremeno smješteni u keš memoriji, prenositi se kroz API pozive, replicirati se između čvorova ili obrađivati u međuservisnoj komunikaciji. Svaka od tih faza predstavlja potencijalno mjesto napada.

„Napadi na podatke mogu imati različite ciljeve. Nekada je cilj krađa povjerljivih informacija, kao što su lični podaci, poslovne tajne, finansijski zapisi ili tehničke konfiguracije. U drugim slučajevima cilj je izmjena ili brisanje podataka, čime se ugrožava integritet sistema. Posebno su opasni napadi koji prolaze neprimijećeno, jer sistem nastavlja raditi sa netačnim ili kompromitovanim informacijama, što može izazvati lančane greške i poslovne posljedice.

Komunikacioni tokovi između komponenti sistema takođe su česta meta. Ako podaci nisu adekvatno šifrovani, ako ne postoji međusobna provjera identiteta ili ako aplikacije vjeruju neprovjerenim izvorima, napadač može pokušati presresti, izmijeniti ili ponoviti komunikaciju. Napadi ponavljanjem zahtjeva, lažnim servisima ili manipulacijom poruka mogu biti posebno opasni u sistemima koji automatski obrađuju transakcije ili komandne poruke.

Zaštita podataka i komunikacionih tokova zato mora biti višeslojna. Potrebno je štititi podatke i u mirovanju i tokom prenosa, validirati porijeklo poruka, ograničiti pristup samo ovlaštenim servisima i osigurati da sistem može otkriti neuobičajene promjene i pokušaje manipulacije“ [1]. U suprotnom, distribuirani sistem može postati funkcionalno ispravan, ali informacijski nepouzdan.

2.4. Napadi na dostupnost servisa i resursa

Dostupnost je jedan od ključnih zahtjeva savremenih distribuiranih sistema, pa su napadi koji je ugrožavaju izuzetno ozbiljni. Cilj ovih napada nije nužno krađa podataka ili preuzimanje sistema, već onemogućavanje njegovog normalnog rada. U praksi se to najčešće postiže preopterećenjem mrežnih resursa, aplikacionih servisa, baza podataka ili drugih kritičnih komponenti. Takvi napadi mogu uzrokovati usporavanje, povremene zastoje ili potpunu nedostupnost usluge.

Distribuirani sistemi jesu otporniji od jednostavnih centralizovanih rješenja jer mogu imati više instanci servisa, replikaciju podataka i mehanizme automatskog oporavka. Ipak, ta otpornost nije neograničena. Ako su arhitektura, balansiranje opterećenja i raspodjela resursa loše projektovani, napad na jednu kritičnu tačku može izazvati širi poremećaj. Na primjer, preopterećenje sistema za autentifikaciju može posredno onemogućiti rad čitavog ekosistema servisa koji zavise od izdavanja tokena.

„Napadi na dostupnost nisu uvijek isključivo spoljašnji i zlonamjerni. Ponekad sistem postaje nedostupan usljed pogrešne konfiguracije, loše implementiranog automatskog skaliranja, nekontrolisanog rasta potrošnje resursa ili loše zaštićenog internog servisa koji ne može podnijeti veći broj poziva. Zbog toga zaštita dostupnosti obuhvata i bezbjednosne i inženjerske mjere“ [3].

U mnogim organizacijama dostupnost servisa direktno je povezana sa finansijskim gubicima, reputacionom štetom i prekidom poslovanja. Zato je zaštita od napada na dostupnost važna podjednako kao i zaštita od krađe podataka. Distribuirani sistem koji je “bezbjedan”, ali često nedostupan, ne može se smatrati kvalitetnim rješenjem.

2.5. Greške konfiguracije i ljudski faktor kao bezbjednosni problem

Iako se bezbjednosni incidenti često predstavljaju kao rezultat sofisticiranih napada, veliki broj stvarnih problema nastaje zbog običnih ljudskih grešaka i loših konfiguracija. U distribuiranim sistemima broj parametara, komponenti i pravila koje treba pravilno podesiti je veoma velik. Dovoljno je da jedan servis ostane izložen bez autentifikacije, da jedna baza podataka bude pogrešno dostupna, da jedno mrežno pravilo bude preširoko ili da jedan nalog ima više privilegija nego što mu je potrebno, pa da nastane ozbiljan rizik.

„Ljudski faktor obuhvata i nedovoljno znanje korisnika, nepažnju administratora, loše procedure, nedosljedno sprovođenje pravila i odsustvo bezbjednosne kulture“ [1]. Zaposleni može otvoriti zlonamjernu poruku, postaviti lozinku koju je lako pogoditi, podijeliti povjerljive podatke preko nebezbjednog kanala ili zaobići proceduru zato što mu se čini komplikovanom. U složenim distribuiranim sistemima takve greške dobijaju još veći značaj, jer jedan propust može imati posljedice na više povezanih servisa.

„Poseban problem su konfiguracije koje nastaju automatski ili se prepisuju između okruženja bez detaljne provjere“ [3]. Na primjer, pravilo koje je u razvojnom okruženju prihvatljivo može u produkciji predstavljati ozbiljan bezbjednosni propust. Ako nema jasnih kontrola, pregleda i validacije konfiguracionih promjena, sistem vremenom postaje prepun “sitnih” odstupanja koja zajedno čine veliku ranjivost.

Zbog toga je organizaciona disciplina jednako važna kao i tehnička zaštita. Bezbjednost distribuiranih sistema zahtijeva standardizaciju, kontrolisane procedure, jasnu dokumentaciju i stalnu edukaciju ljudi koji sa sistemom rade. Bez toga će i najsavremenija tehnološka rješenja ostati nedovoljno iskorišćena.

3. KLJUČNI ZAHTJEVI I PRINCIPI BEZBJEDNOSTI U DISTRIBUIRANIM SISTEMIMA

3.1. Očuvanje povjerljivosti podataka

Povjerljivost podataka predstavlja osnovni bezbjednosni zahtjev u sistemima koji obrađuju osjetljive informacije, a u distribuiranim okruženjima njena zaštita postaje složenija nego u lokalnim sistemima. Podaci se ne čuvaju samo na jednom mjestu, već putuju kroz mrežu, koriste ih različiti servisi i često se repliciraju između više čvorova. To znači da je zaštita potrebna u više faza i na više nivoa.

„Očuvanje povjerljivosti počinje pravilnom klasifikacijom podataka. Nije svaki podatak podjednako osjetljiv, ali sistem mora jasno znati koje informacije zahtijevaju strožu zaštitu. Lični podaci, finansijski zapisi, autentifikacioni tokeni, poslovne tajne i tehničke konfiguracije ne smiju se tretirati kao obični javni podaci. Tek kada se zna šta se štiti i zašto, moguće je odabrati odgovarajuće mjere“ [3].

U distribuiranim sistemima povjerljivost se ostvaruje kombinacijom kontrole pristupa, kriptografije, segmentacije mreže i pravilnog rukovanja podacima u aplikacionoj logici. Samo šifrovanje komunikacije nije dovoljno ako više servisa ima nepotreban pristup istim informacijama. Slično tome, ni stroga pravila pristupa nijesu dovoljna ako se osjetljivi podaci zapisuju u logove, keš memoriju ili privremene fajlove bez odgovarajuće zaštite.

Posebno je važno razumjeti da se povjerljivost odnosi i na servisne identitete i tehničke podatke. U mnogim incidentima napadač ne traži odmah korisničke podatke, već najprije prikuplja informacije o arhitekturi sistema, konfiguracionim pravilima, internoj adresaciji i tehničkim tajnama. Takvi podaci kasnije mu služe kao osnova za dalju kompromitaciju sistema.

3.2. Očuvanje integriteta sistema i informacija

Integritet znači da podaci, konfiguracije i funkcionalni tokovi sistema ostaju tačni, potpuni i neizmijenjeni osim kada ovlašćeni subjekti izvrše legitimnu promjenu. „U distribuiranim sistemima očuvanje integriteta je posebno izazovno zato što više komponenti može paralelno čitati i mijenjati iste ili povezane informacije. Ako se tome dodaju mrežna kašnjenja, replikacija i mogućnost djelimičnih kvarova, postaje jasno zašto integritet mora biti pažljivo projektovan“ [3].

„Narušavanje integriteta ne mora biti spektakularno. Nekada je dovoljno da se neprimjetno izmijeni jedna vrijednost, da se promijeni konfiguracioni parametar, da se lažira poruka između servisa ili da jedna kopija podataka ostane neusklađena sa drugom. Posljedice takvih izmjena mogu biti ogromne, naročito u finansijskim, zdravstvenim i industrijskim sistemima. Sistem može nastaviti da radi, ali sa pogrešnim pretpostavkama i netačnim rezultatima“ [1].

Zaštita integriteta zahtijeva kontrole na više nivoa. Potrebno je validirati ulazne podatke, osigurati bezbjedne transakcione mehanizme, kontrolisati promjene konfiguracije, koristiti kriptografske potpise i provjere cjelovitosti tamo gdje je potrebno, te jasno definisati ko i pod kojim uslovima

smije vršiti izmjene. U distribuiranim sistemima veoma je važno i obezbijediti konzistentnost između više instanci i replika podataka.

Integritet se odnosi i na sam softver. Ako napadač kompromituje aplikacioni kod, skripte za automatizaciju, slike kontejnera ili pakete zavisnosti, sistem može biti ugrožen i prije nego što uopšte počne raditi. Zato zaštita integriteta uključuje i provjeru izvora softvera, kontrolu procesa isporuke i zaštitu razvojnih i produkcionih okruženja.

3.3. Obezbjeđenje dostupnosti i otpornosti sistema

Dostupnost je bezbjednosni zahtjev koji se često potcjenjuje dok ne dođe do prekida rada. U distribuiranim sistemima od servisa se očekuje da budu stalno ili gotovo stalno na raspolaganju korisnicima i drugim servisima. Da bi se to postiglo, arhitektura mora biti otporna na kvarove, preopterećenja, mrežne smetnje i zlonamjerne pokušaje ometanja rada.

Otpornost sistema znači sposobnost da sistem nastavi da funkcioniše i kada pojedine komponente zakažu ili budu napadnute. To se postiže kroz redundansu, replikaciju, balansiranje opterećenja, automatski oporavak, nadzor zdravlja servisa i planove kontinuiteta poslovanja. U savremenim distribuiranim okruženjima ovo više nije luksuz, već osnovni zahtjev. Sistem koji zavisi od jedne tačke otkaza ne može se smatrati dovoljno sigurnim ni dovoljno pouzdanim.

Ipak, dostupnost nije samo tehničko pitanje broja servera i rezervnih kopija. Ona zavisi i od toga koliko su servisi međusobno zavisni, da li postoje skrivena uska grla, kako se upravlja redovima poruka, kako se izdaju identiteti i da li je sistem sposoban da graciozno odbije dio saobraćaja umjesto da potpuno otkáže. Dobro projektovana otpornost podrazumijeva i kontrolisano degradiranje funkcionalnosti, a ne samo idealno funkcionisanje u savršenim uslovima.

Iz bezbjednosnog ugla, dostupnost se mora planirati kao dio ukupne odbrane. Napadi na dostupnost često imaju za cilj da prikriju druge aktivnosti, da oslabe nadzor ili da prisile timove na hitne i rizične promjene. Zato otpornost nije samo zaštita od prekida rada, već i važna komponenta ukupne bezbjednosne strategije.

3.4. Upravljanje identitetom i kontrola pristupa

„Upravljanje identitetom jedno je od najvažnijih pitanja u distribuiranim sistemima zato što se praktično svaka interakcija zasniva na nekoj formi povjerenja. Korisnik vjeruje aplikaciji, aplikacija vjeruje servisu za autentifikaciju, jedan mikroservis vjeruje drugom servisu, a administrativni alati vjeruju tehničkim nalogima i agentima. Ako identiteti nijesu jasno definisani, pravilno potvrđeni i ograničeni na neophodan obim prava, sistem postaje nestabilan i ranjiv“ [3].

Kontrola pristupa mora odgovoriti na nekoliko ključnih pitanja. Ko traži pristup, kako se potvrđuje njegov identitet, kojem resursu pristupa, koju operaciju pokušava izvršiti i u kojem kontekstu to radi. U manjim sistemima ove odluke mogu biti relativno jednostavne, ali u distribuiranim arhitekturama sa više servisa i korisničkih uloga to postaje složen problem koji zahtijeva centralna pravila i dosljedno sprovođenje.

Poseban izazov predstavlja činjenica da se pristup ne dodjeljuje samo ljudima. Veliki broj radnji u savremenim sistemima obavljaju aplikacije, servisi, pozadinski procesi i automatizovani zadaci. Njima su potrebni identiteti, tokeni, ključevi i precizno definisana prava. Ako se servisnim identitetima dodijele prevelike privilegije, kompromitacija jednog procesa može dovesti do šireg proboja kroz sistem.

Zato su principi najmanjih privilegija i kontrole pristupa zasnovane na ulozi, atributima ili kontekstu od presudnog značaja. Svaki korisnik i svaki servis treba da imaju samo onaj pristup koji im je zaista potreban, i to samo onoliko dugo koliko je potrebno. Ovakav pristup smanjuje posljedice eventualne kompromitacije i čini sistem lakšim za nadzor i reviziju.

3.5. Praćenje aktivnosti, revizija i odgovornost korisnika

Bez mogućnosti praćenja aktivnosti nijedan ozbiljan bezbjednosni sistem ne može biti potpun. U distribuiranim sistemima je posebno važno znati ko je, kada, gdje i pod kojim uslovima izvršio određenu radnju. Jedna korisnička akcija može proizvesti više poziva između servisa, promjene u bazama podataka, izdavanje novih tokena i upis događaja u različite logove. Ako se ti tragovi ne mogu povezati, istraga incidenta postaje izuzetno teška.

Revizijski tragovi imaju dvostruku funkciju. S jedne strane služe operativnoj i bezbjednosnoj analizi, jer pomažu da se otkriju anomalije, pokušaji zloupotrebe, neobično ponašanje i tokovi napada. S druge strane, oni omogućavaju odgovornost i kontrolu usklađenosti, što je važno u organizacijama koje moraju dokazivati ko je pristupao kojim podacima i zašto. U nekim sektorima, kao što su finansije i zdravstvo, ovo je i zakonska obaveza.

„Praćenje aktivnosti ne smije biti površno. Ako sistem zapisuje previše podataka bez strukture, logovi postaju neupotrebljivi. Ako zapisuje premalo, kritične informacije mogu izostati. Potrebna je ravnoteža između detaljnosti i preglednosti, kao i mogućnost centralizovane analize i korelacije događaja. Posebno je važno uskladiti vrijeme, identifikatore zahtjeva i način obilježavanja korisničkih i servisnih aktivnosti kroz različite komponente sistema“ [1].

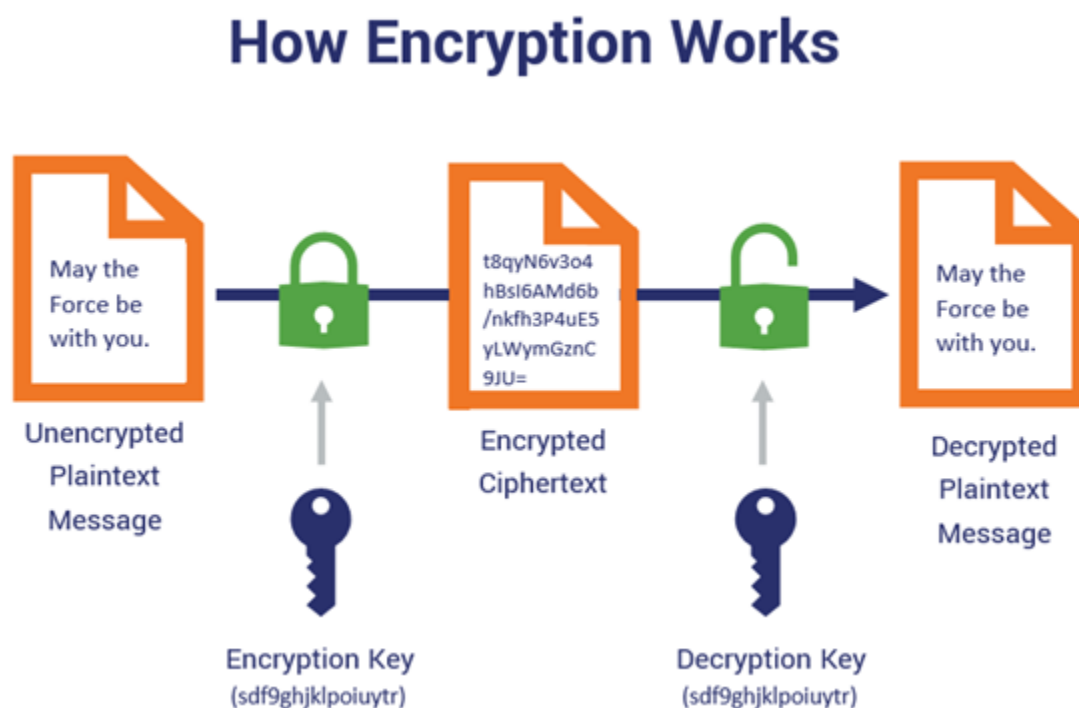
Odgovornost korisnika i servisa time postaje stvarna, a ne samo formalna. Kada postoji vjerodostojan trag aktivnosti, lakše je otkriti zloupotrebu, utvrditi uzrok problema i poboljšati pravila pristupa. Zbog toga revizija i nadzor nijesu samo pomoćni alati, već sastavni dio bezbjednosne arhitekture distribuiranih sistema.

4. TEHNIKE I RJEŠENJA ZA ZAŠTITU DISTRIBUIRANIH SISTEMA

4.1. Kriptografija i zaštita podataka

„Kriptografija predstavlja jedno od osnovnih sredstava za zaštitu informacija u distribuiranim sistemima. Njena uloga nije ograničena samo na šifrovanje osjetljivih podataka, već obuhvata i očuvanje integriteta, autentifikaciju komunikacionih partnera i zaštitu digitalnih identiteta. U distribuiranim sistemima kriptografija ima višestruku ulogu zato što podaci neprekidno prelaze između različitih čvorova i servisa“ [2].

Zaštita podataka u mirovanju obično podrazumijeva šifrovanje baza podataka, diskova, rezervnih kopija i drugih mjesta na kojima se informacije trajno ili privremeno čuvaju. Ovakva zaštita posebno je važna u okruženjima gdje postoji mogućnost fizičkog pristupa medijima, krađe rezervnih kopija ili kompromitacije host sistema. Međutim, šifrovanje podataka u mirovanju nije dovoljno ako su ključevi za dešifrovanje loše zaštićeni ili ako aplikacije pristupaju podacima bez odgovarajućih autorizacionih kontrola.



Slika 3 - Proces kriptovanja podataka

Zaštita podataka tokom prenosa jednako je važna. Kada servisi komuniciraju preko mreže, potrebno je osigurati da treća strana ne može presresti ili izmijeniti informacije. U tu svrhu koriste se sigurni protokoli i mehanizmi razmjene ključeva. U modernim distribuiranim sistemima podrazumijeva se da se osjetljiva komunikacija ne odvija u otvorenom tekstu, čak ni unutar “interne” mreže.

„Ipak, kriptografija sama po sebi nije čarobno rješenje. Njen kvalitet zavisi od pravilnog izbora algoritama, sigurnog upravljanja ključevima, pravilne implementacije i razumijevanja gdje i zašto se koristi. U praksi se vrlo često dešava da je algoritam jak, ali je njegov ključ pohranjen na nezaštićenom mjestu, što cijeli mehanizam čini besmislenim. Zato kriptografiju uvijek treba posmatrati kao dio šireg sistema upravljanja bezbjednošću“ [3].

4.2. Digitalni sertifikati, PKI i bezbjedni komunikacioni protokoli

Digitalni sertifikati i infrastruktura javnih ključeva imaju važnu ulogu u uspostavljanju povjerenja između komponenti distribuiranog sistema. Kada jedan servis komunicira sa drugim servisom, nije dovoljno samo šifrovati vezu. Potrebno je i potvrditi identitet druge strane kako bi se spriječilo lažno predstavljanje i povezivanje sa zlonamjernim ili kompromitovanim komponentama. Upravo tu ulogu imaju sertifikati i mehanizmi javnog ključa.

Infrastruktura javnih ključeva omogućava izdavanje, provjeru, obnavljanje i opoziv digitalnih sertifikata. U distribuiranim sistemima ona je važna ne samo za korisničke aplikacije i web servise, već i za međusobnu provjeru servisa, mašina i orkestracionih komponenti. Kada se ovakav model pravilno primijeni, svaki važan entitet u sistemu može imati provjerljiv digitalni identitet.

Bezbjedni komunikacioni protokoli kao što su oni zasnovani na TLS zaštiti omogućavaju enkripciju saobraćaja i potvrdu identiteta komunikacionih strana. Na taj način se smanjuje rizik od presretanja i manipulacije podacima. U modernim distribuiranim arhitekturama sve je češća praksa da se čak i interna komunikacija između mikroservisa obavezno šifrira, jer pretpostavka da je “unutrašnja mreža sigurna” više nije dovoljna.

Naravno, sertifikati i sigurni protokoli uvode i operativnu složenost. Sertifikati imaju rok trajanja, moraju se obnavljati, čuvati i pravilno raspoređivati. Ako se tim procesima ne upravlja pažljivo, može doći do prekida komunikacije ili do nebezbjednog zaobilaženja provjera. Zato je automatizacija upravljanja sertifikatima i jasna kontrola životnog ciklusa ključeva veoma važna.

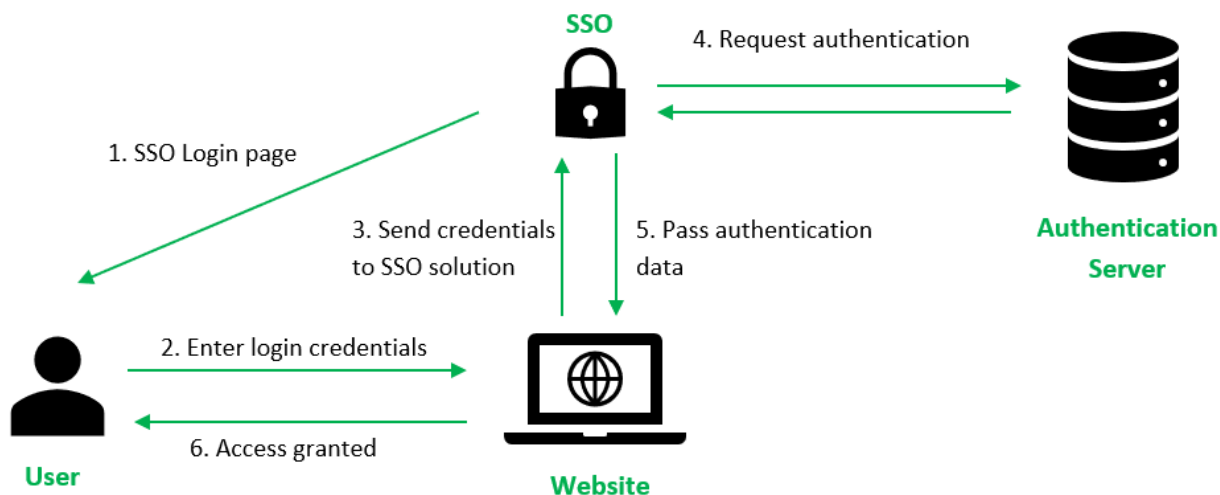
4.3. Autentifikacija korisnika i višefaktorska zaštita

Autentifikacija korisnika predstavlja prvu liniju odbrane u velikom broju sistema. Ako se identitet korisnika ne može pouzdano potvrditi, sve ostale bezbjednosne mjere gube na vrijednosti. U distribuiranim sistemima autentifikacija često prevazilazi jednostavnu provjeru lozinke i uključuje centralne servise identiteta, tokene, federativnu prijavu i višefaktorske mehanizme.

„Višefaktorska autentifikacija znači da se identitet potvrđuje kombinovanjem najmanje dva različita faktora, kao što su nešto što korisnik zna, nešto što posjeduje ili nešto što jeste. Ovaj pristup znatno smanjuje rizik da krađa lozinke sama po sebi bude dovoljna za neovlašćen pristup. U okruženjima gdje se pristupa osjetljivim podacima ili administrativnim funkcijama, višefaktorska zaštita postaje gotovo obavezna“ [2].

U distribuiranim sistemima izazov nije samo prijava krajnjeg korisnika, već i prenos i validacija identiteta kroz veći broj servisa. Nakon uspješne autentifikacije korisnik često dobija token ili drugi oblik dokaza o identitetu, koji zatim koriste različite komponente sistema. Ako se ti tokeni

izdaju preširoko, traju predugo ili se ne provjeravaju dosljedno, sistem ostaje ranjiv i pored formalno “uspješne” prijave.



Slika 4 - Autentifikacija korisnika pomoću SSO-a

Dobra autentifikacija zato nije samo ulazna barijera, već pažljivo upravljani proces kroz čitav tok rada. Potrebno je ograničiti trajanje sesija, provjeravati rizične prijave, pratiti sumnjive pokušaje pristupa i uskladiti bezbjednost sa upotrebljivošću. Ako je sistem previše komplikovan za legitimne korisnike, oni će pokušati da zaobiđu pravila, čime se ponovo povećava rizik.

4.4. Modeli autorizacije i upravljanje privilegijama

Nakon što je identitet potvrđen, slijedi pitanje šta je tom identitetu dozvoljeno. Autorizacija je zato jednako važna kao i autentifikacija, a u distribuiranim sistemima često i složenija. Razlog je to što prava pristupa moraju biti dosljedno sprovedena kroz veći broj servisa, baza podataka, interfejsa i administrativnih slojeva.

„Jedan od najčešćih pristupa jeste kontrola pristupa zasnovana na ulogama, gdje se korisnicima dodjeljuju uloge, a uloge određuju prava. Ovakav model je pregledan i lakši za upravljanje u mnogim poslovnim sistemima“ [1]. Međutim, u savremenim distribuiranim okruženjima često nije dovoljan, jer pristup zavisi i od konteksta, okruženja, vremena, vrste uređaja, stanja sistema i drugih atributa. Zbog toga se sve češće koriste napredniji modeli zasnovani na atributima i politikama.

Upravljanje privilegijama posebno je važno za administrativne i tehničke naloge. Nije rijetkost da zbog praktičnosti servisi dobiju više prava nego što im je stvarno potrebno. Takav pristup kratkoročno pojednostavljuje implementaciju, ali dugoročno stvara ogroman rizik. Ako napadač kompromituje preprivilegovani servisni nalog, može dobiti mnogo širi pristup nego što bi to bilo moguće kroz običan korisnički nalog.

Zato autorizacija mora biti precizna, revizibilna i dinamički kontrolisana. Svaka privilegija treba da ima jasno opravdanje, vremensko trajanje i odgovornost. U ozbiljnim sistemima prava pristupa

se redovno preispituju, višak privilegija uklanja, a osjetljive operacije dodatno odobravaju ili nadziru. Time se smanjuje vjerovatnoća da jedna greška ili kompromitacija ugrozi cijeli sistem.

4.5. Segmentacija mreže, izolacija servisa i zaštitni mehanizmi

„Jedna od najsnažnijih odbrambenih tehnika u distribuiranim sistemima jeste ograničavanje kretanja napadača kroz mrežu i između servisa. To se postiže segmentacijom mreže, izolacijom komponenti i pravilima koja dopuštaju samo nužnu komunikaciju. Umjesto da svaki servis može pristupiti svakom drugom servisu ili mrežnom segmentu, uspostavlja se strogo definisan skup dozvoljenih tokova“ [2].

Segmentacija mreže smanjuje rizik da kompromitacija jedne tačke preraste u kompromitaciju cijelog sistema. Ako napadač dobije pristup jednom manje važnom servisu, ne bi smio automatski imati mogućnost pristupa bazama podataka, upravljačkim interfejsima i internim administrativnim mrežama. Ovakav pristup zahtijeva pažljivo planiranje arhitekture i pravila komunikacije, ali je izuzetno efikasan u ograničavanju štete.

Izolacija servisa je posebno važna u mikroservisnim i kontejnerskim okruženjima. „Iako servisi moraju međusobno komunicirati, to ne znači da svi treba da dijele isti mrežni prostor, iste tajne i isti nivo povjerenja. Dobra praksa nalaže da svaki servis ima jasno definisanu ulogu, ograničene privilegije i samo one konekcije koje su mu zaista potrebne“ [1]. Time se i slučajna greška i zlonamjerna aktivnost lakše zadržavaju u užem opsegu.

„Zaštitni mehanizmi, kao što su mrežni filteri, aplikacioni zaštitni zidovi, sistemi za detekciju upada i kontrole izlaznog saobraćaja, dodatno pojačavaju ovu odbranu. Ipak, njihova efikasnost zavisi od pravilnog podešavanja. Ako su pravila preširoka, zaštita slabi. Ako su prestroga i nedovoljno promišljena, mogu ometati legitiman rad sistema. Zbog toga je ova oblast uvijek spoj bezbjednosne discipline i dobrog arhitektonskog razumijevanja“ [1].

4.6. Evidencija događaja, nadzor i odgovor na incidente

„Upravljanje bezbjednošću ne završava se postavljanjem zaštitnih mehanizama. Neophodno je stalno posmatrati ponašanje sistema, prikupljati relevantne događaje i imati jasan plan kako reagovati kada se incident dogodi. U distribuiranim sistemima ovo je posebno važno, jer napadi često nijesu trenutni i očigledni, već se odvijaju postepeno kroz više komponenti“ [2].

Evidencija događaja mora biti dovoljno detaljna da omogući rekonstrukciju onoga što se dogodilo, ali i dovoljno strukturisana da se iz ogromne količine informacija mogu izdvojiti relevantni signali. Logovi autentifikacije, promjena konfiguracije, mrežnih konekcija, poziva API interfejsa, grešaka servisa i administrativnih akcija moraju biti dostupni za analizu. U velikim distribuiranim sistemima to obično znači centralizovano prikupljanje i korelaciju događaja.

Nadzor sistema ne smije se svesti samo na tehničke metrike poput iskorišćenja procesora ili memorije. Potrebno je pratiti i bezbjednosne indikatore, kao što su neuobičajeni obrasci prijave, neuspjeli pokušaji pristupa, iznenadne promjene privilegija, masovna čitanja podataka, nepoznati

mrežni tokovi ili odstupanja u ponašanju servisa. Savremeni sistemi nadzora sve češće koriste i automatizovane mehanizme za prepoznavanje anomalija.

Odgovor na incidente podrazumijeva spremnost organizacije da brzo otkrije, ograniči, analizira i sanira problem. U distribuiranim sistemima to znači znati kako izolovati pogođene komponente, opozvati kompromitovane identitete, obnoviti servise, sačuvati forenzičke tragove i obavijestiti relevantne strane. Bez unaprijed pripremljenih procedura reakcija često kasni ili postaje haotična, što dodatno povećava štetu.

5. BEZBJEDNOST U SAVREMENIM ARHITEKTURAMA DISTRIBUIRANIH SISTEMA

5.1. Bezbjednost cloud okruženja

„Cloud okruženja predstavljaju jedan od najvažnijih oblika savremenih distribuiranih sistema. Njihova prednost leži u elastičnosti, dostupnosti, lakoći proširenja i mogućnosti da organizacije koriste infrastrukturu bez potrebe da sve fizički održavaju same. Međutim, cloud uvodi i posebne bezbjednosne izazove. Resursi su virtuelizovani, servisi se brzo pokreću i gase, podaci mogu biti raspoređeni kroz različite regije, a veliki dio kontrole dijeli se između korisnika usluge i cloud provajdera“ [1].

Jedan od ključnih izazova jeste razumijevanje modela podijeljene odgovornosti. Organizacija često pretpostavlja da je cloud automatski “bezbjedan” sam po sebi, ali provajder uglavnom štiti osnovnu infrastrukturu, dok korisnik ostaje odgovoran za konfiguraciju servisa, upravljanje pristupom, zaštitu podataka i aplikacionu logiku. Veliki broj incidenata u cloud okruženjima nastaje upravo zato što su skladišta podataka javno izložena, pravila pristupa preširoka ili identiteti loše upravljani.

Cloud bezbjednost dodatno komplikuje dinamičnost okruženja. Resursi se kreiraju automatski, mijenjaju se u kratkim vremenskim intervalima i često ne ostaju trajno prisutni. To otežava klasični ručni nadzor i zahtijeva automatizovane kontrole, stalnu provjeru konfiguracija i precizno upravljanje politikama pristupa. Posebno su osjetljive tajne, pristupni ključevi i tehnički identiteti koji se koriste za komunikaciju između cloud servisa.

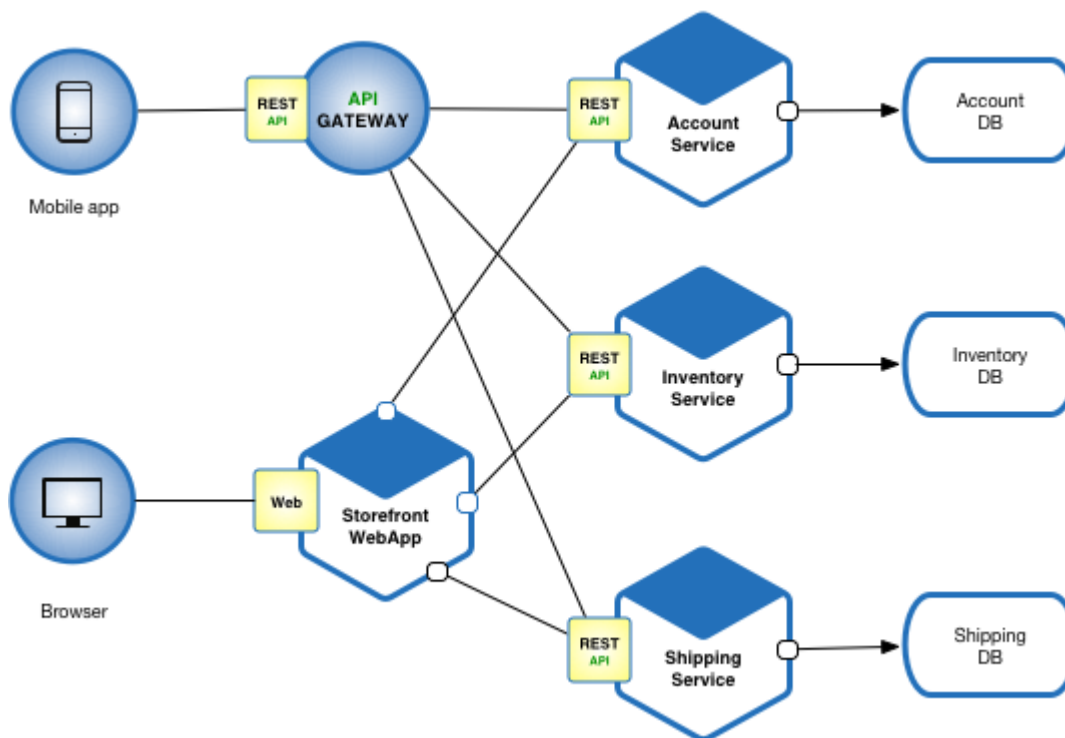
Iako cloud pruža mnogo naprednih bezbjednosnih mogućnosti, kao što su centralno upravljanje identitetom, automatsko šifrovanje i integrisani nadzor, njihova korist zavisi od pravilne primjene. Cloud nije ni inherentno nebezbjedan ni inherentno siguran. Njegov stvarni nivo bezbjednosti zavisi od toga koliko organizacija razumije rizike i koliko disciplinovano upravlja svojim distribuiranim resursima u takvom okruženju.

5.2. Bezbjednost mikroservisnih arhitektura

Mikroservisna arhitektura donijela je veliku fleksibilnost u razvoju i skaliranju aplikacija, ali je istovremeno otvorila i nova bezbjednosna pitanja. Umjesto jedne veće aplikacije, sistem se sastoji od velikog broja manjih servisa koji međusobno komuniciraju preko mreže. To znači da broj interakcija naglo raste, a sa njim i broj mjesta na kojima može doći do greške, presretanja ili zloupotrebe.

Jedan od osnovnih izazova mikroservisa jeste međuservisno povjerenje. Ako se svaki servis implicitno smatra legitimnim samo zato što je “dio internog sistema”, napadač koji kompromituje jednu komponentu može lako iskoristiti to povjerenje za dalje napredovanje. Zato se u sigurnim mikroservisnim arhitekturama sve više insistira na međusobnoj autentifikaciji servisa, šifrovanju komunikacije i preciznim pravilima autorizacije za svaku interakciju.

Drugi problem je širenje tajni i konfiguracija. Svaki servis može imati svoje ključeve, tokene, konekcione stringove i druge osjetljive podatke. Ako se njima ne upravlja centralno i bezbjedno, sistem brzo postaje težak za kontrolu i sklon curenju osjetljivih informacija. Mikroservisi takođe otežavaju praćenje aktivnosti, jer jedna korisnička radnja prolazi kroz mnogo manjih komponenti, a svaka generiše sopstvene logove i događaje.



Slika 5 - Mikroservisna arhitektura

Uprkos tim izazovima, mikroservisna arhitektura može biti veoma bezbjedna ako je pravilno projektovana. Njena prednost je i to što omogućava finiju segmentaciju funkcionalnosti i pristupa. Ako svaki servis ima jasno definisanu odgovornost i minimalan opseg prava, kompromitacija jednog dijela sistema može ostati ograničena. Međutim, to zahtijeva disciplinu, standardizaciju i visok nivo automatizacije bezbjednosnih kontrola.

5.3. Bezbjednost API interfejsa i servisne komunikacije

API interfejsi predstavljaju jednu od najvažnijih kontaktnih tačaka savremenih distribuiranih sistema. Kroz njih aplikacije razmjenjuju podatke, aktiviraju procese i povezuju različite funkcionalnosti. Upravo zato API bezbjednost ima ogroman značaj. Ako je API loše dizajniran ili nedovoljno zaštićen, napadač može iskoristiti njegove funkcije za pristup podacima, zaoblazanje poslovnih pravila ili preopterećenje sistema.

„Bezbjednost API interfejsa počinje jasnim definisanjem ko smije pristupiti kojem resursu i pod kojim uslovima. Potrebno je provoditi autentifikaciju i autorizaciju za svaki relevantan zahtjev, validirati ulazne podatke, ograničiti broj pokušaja i zaštititi se od zloupotrebe sesija i tokena. Posebno su osjetljivi interfejsi koji omogućavaju pretragu, masovni izvoz podataka, promjenu konfiguracije ili administrativne operacije“ [1].

U distribuiranim sistemima API bezbjednost obuhvata i internu komunikaciju između servisa. Ponekad se interni API-i manje strogo štite od spoljašnjih, pod pretpostavkom da nijesu izloženi. To je opasna praksa, jer upravo interni interfejsi često postaju cilj nakon početne kompromitacije sistema. Zbog toga svaka važna servisna komunikacija mora imati jasne kontrole identiteta, šifrovanje i ograničenja poziva.

Dobro zaštićen API ne znači samo “zaključan” API. Potrebno je postići ravnotežu između funkcionalnosti, performansi i kontrole. Ako su pravila nejasna ili nekonzistentna, korisnici i programeri će pokušavati zaobilazna rješenja. Zato su standardizacija, dosljedna implementacija i dokumentovane politike pristupa ključni za bezbjednost ovog sloja distribuiranog sistema.

5.4. Bezbjednost kontejnera i orkestracionih platformi

Kontejnerska okruženja i sistemi za orkestraciju postali su standardan dio moderne distribuirane infrastrukture. Oni omogućavaju brzo raspoređivanje servisa, efikasno korišćenje resursa i automatizovano upravljanje velikim brojem aplikacionih komponenti. Međutim, upravo ta fleksibilnost i automatizacija unose i nove bezbjednosne izazove koji se razlikuju od onih u tradicionalnim serverskim okruženjima.

Bezbjednost kontejnera počinje od samih slika iz kojih se servisi pokreću. Ako slika sadrži ranjive pakete, nepotrebne alate, loše podešene korisnike ili osjetljive podatke, svaki kontejner pokrenut iz nje nasljeđuje te probleme. Zbog toga je veoma važno kontrolisati porijeklo slika, redovno ih ažurirati i skenirati na ranjivosti prije upotrebe.

Orkestracione platforme dodatno centralizuju upravljanje, što je istovremeno i prednost i rizik. Ako napadač dobije pristup komponentama orkestracije, može upravljati velikim brojem servisa, mijenjati konfiguracije, pristupati tajnama i širiti uticaj kroz cijeli sistem. Zbog toga su zaštita upravljačkih ravni, stroga kontrola pristupa i revizija administrativnih aktivnosti posebno važni u ovim okruženjima.

Takođe, mrežna pravila između kontejnera i servisa moraju biti pažljivo definisana. Podrazumijevana otvorenost komunikacije može olakšati razvoj, ali u bezbjednosnom smislu predstavlja ozbiljan problem. Kontejnerska platforma treba da podrži segmentaciju, međusobnu autentifikaciju i sigurno upravljanje tajnama, a organizacija mora imati znanje i disciplinu da te mogućnosti zaista i iskoristi.

6. IZAZOVI IMPLEMENTACIJE BEZBJEDNOSTI U DISTRIBUIRANIM SISTEMIMA

6.1. Složenost infrastrukture i veliki broj komponenti

Jedan od najvećih praktičnih izazova bezbjednosti u distribuiranim sistemima jeste sama složenost infrastrukture. „Kako sistem raste, broj servisa, mrežnih segmenata, baza podataka, keš slojeva, redova poruka, upravljačkih alata, API interfejsa i identiteta postaje veoma velik. Svaka od tih komponenti uvodi sopstvena pravila, konfiguracije i potencijalne ranjivosti“ [2]. U takvom okruženju veoma je teško održati jasan i ažuran pregled nad stanjem sistema.

Složenost nije problem samo zato što postoji mnogo komponenti, već zato što one međusobno zavise jedna od druge. Promjena u jednom servisu može uticati na pristupne politike drugog, nadogradnja jedne platforme može promijeniti bezbjednosne pretpostavke treće, a nova integracija može otvoriti neočekivanu putanju komunikacije. Ako organizacija nema arhitektonsku disciplinu i jasan model upravljanja, bezbjednost postaje fragmentisana i reaktivna.

„Poseban problem predstavlja to što složeni sistemi često dugo rastu organski, bez potpunog redizajna. Vremenom se gomilaju stara pravila, zastarjele privilegije, napušteni servisi i privremena rješenja koja nikada nijesu uklonjena. Takvo „naslijeđeno stanje“ često predstavlja najveći rizik, jer niko više nije siguran zašto je nešto postavljeno baš tako i da li je i dalje potrebno. „ [1] Zbog toga je jedan od najvažnijih zadataka bezbjednosnog upravljanja pojednostavljivanje gdje god je moguće. Svaka nepotrebna komponenta, nepotrebna veza i nepotrebna privilegija povećavaju složenost i time rizik. Dobro upravljanje složenošću zato nije samo pitanje urednosti sistema, već suštinski dio njegove zaštite.

6.2. Balans između performansi i bezbjednosti

U praksi se vrlo često javlja napetost između bezbjednosti i performansi. Svaka dodatna provjera identiteta, enkripcija poruka, validacija zahtjeva, revizijski zapis ili mrežni filter uvodi određeni trošak u pogledu vremena, procesora, memorije ili složenosti implementacije. U distribuiranim sistemima, gdje se odvija veliki broj poziva između komponenti, taj trošak može postati vidljiv ako se rješenja ne primjenjuju pažljivo.

„Međutim, suprotstavljanje bezbjednosti i performansi često je pogrešno postavljeno. Sistem koji je brz, ali lako kompromitovan, nije kvalitetan. Isto tako, sistem koji je previše spor, komplikovan i operativno težak zbog pretjeranih bezbjednosnih mjera može postati neupotrebljiv. Pravi zadatak nije izabrati jedno ili drugo, već pronaći način da se zaštita uklopi u arhitekturu tako da bude efikasna, ali i održiva“ [2].

To zahtijeva razumijevanje rizika i prioriteta. Nije svaki tok podataka jednako osjetljiv, niti svaka operacija zahtijeva isti nivo provjere. Bezbjednosne mjere treba primjenjivati tamo gdje donose najveću vrijednost i gdje je potencijalna šteta najveća. U nekim slučajevima moguće je koristiti optimizovane protokole, lokalno keširanje bezbjednosnih odluka ili hardversku podršku za kriptografiju, čime se smanjuje opterećenje.

Balans između performansi i bezbjednosti zato nije jednokratna odluka, već stalan proces mjerenja, prilagođavanja i provjere. Organizacija mora razumjeti svoje poslovne prioritete, ali i realne prijetnje. Samo tako može izgraditi sistem koji je i siguran i operativno efikasan.

6.3. Upravljanje tajnama, ključevima i sertifikatima

Jedan od tehnički najosjetljivijih izazova u distribuiranim sistemima jeste upravljanje tajnama. Pod tajnama se podrazumijevaju lozinke, API ključevi, tokeni, privatni ključevi, sertifikati, konekcionci podaci i drugi povjerljivi elementi koji omogućavaju pristup resursima ili zaštitu komunikacije. U jednostavnijim sistemima broj takvih elemenata može biti ograničen, ali u složenim distribuiranim arhitekturama njihov broj rapidno raste.

Glavni problem nije samo gdje se tajne čuvaju, već kako se izdaju, ko im pristupa, koliko dugo važe i kako se obnavljaju ili opozivaju. Ako se ključ koristi predugo, povećava se rizik da će biti kompromitovan. Ako se prečesto mijenja bez automatizacije, sistem može postati nestabilan i sklon prekidima. Ako ne postoji pregled nad time koji servis koristi koji ključ, incident postaje težak za saniranje.

Posebno je opasna praksa čuvanja tajni u izvornom kodu, otvorenim konfiguracionim fajlovima ili ručno distribuiranim dokumentima. Takva rješenja možda djeluju praktično tokom razvoja, ali u produkcionom okruženju predstavljaju ozbiljan rizik. Jednom kada tajna procuri, potrebno je znati gdje je sve korišćena i kako je zamijeniti bez rušenja rada sistema.

Zbog toga savremeni distribuirani sistemi sve više koriste posebne mehanizme za centralizovano i kontrolisano upravljanje tajnama. Ipak, ni najbolji alat ne pomaže ako organizacija nema jasna pravila, odgovornost i disciplinu u radu sa osjetljivim podacima. Upravljanje tajnama je oblast gdje tehničko rješenje i organizaciona praksa moraju biti potpuno usklađeni.

6.4. Usaglašenost sa propisima i zaštita privatnosti

Savremeni informacioni sistemi ne funkcionišu samo u tehničkom okviru, već i u pravnom i regulatornom okruženju. Organizacije koje obrađuju lične podatke, finansijske informacije, zdravstvene zapise ili druge osjetljive informacije dužne su da poštuju različite propise i standarde. U distribuiranim sistemima ovo pitanje postaje još složenije zato što se podaci mogu obrađivati na više lokacija, kroz više servisa i u različitim jurisdikcijama.

Zaštita privatnosti nije isto što i opšta bezbjednost, iako su međusobno povezane. Sistem može biti tehnički dobro zaštićen, ali i dalje obrađivati više podataka nego što je potrebno, čuvati ih predugo ili omogućavati preširok pristup legitimnim korisnicima. U takvom slučaju privatnost korisnika nije adekvatno zaštićena. Zato se pored tehničkih mjera moraju definisati i pravila o minimizaciji podataka, rokovima čuvanja, legitimnoj svrsi obrade i pravima korisnika.

Distribuirana priroda sistema otežava i dokazivanje usklađenosti. Organizacija mora znati gdje se podaci nalaze, ko im pristupa, u koje svrhe se koriste i kako se brišu ili anonimizuju kada više nijesu potrebni. Ako takav pregled ne postoji, usklađenost postaje formalna, a ne stvarna. To može imati i pravne i reputacione posljedice.

Zato zaštita privatnosti i regulatorna usklađenost moraju biti ugrađene u arhitekturu i procese od samog početka. Nije dovoljno naknadno “dodati” nekoliko pravila ili obavještenja korisnicima. Potrebno je razumjeti tokove podataka kroz cijeli distribuirani sistem i projektovati ih na način koji poštuje i bezbjednosne i pravne zahtjeve.

6.5. Održavanje, nadzor i forenzička analiza u distribuiranom okruženju

Čak i kada je sistem dobro projektovan, bezbjednost nije statično stanje. Servisi se mijenjaju, zavisnosti se ažuriraju, mrežni tokovi se prilagođavaju, a napadači pronalaze nove metode. Zato je održavanje bezbjednosti stalan proces, a u distribuiranim sistemima taj proces je zahtjevniji nego u manjim okruženjima. Svaka promjena može proizvesti neočekivane posljedice i zato mora biti pažljivo kontrolisana.

Nadzor sistema, kao što je već istaknuto, mora obuhvatiti više vrsta događaja i omogućiti njihovo povezivanje. Međutim, sama količina podataka može biti problem. U velikim distribuiranim sistemima generiše se ogroman broj logova i metrika, a među njima treba na vrijeme pronaći signal koji ukazuje na napad ili ozbiljan propust. Bez dobre filtracije, korelacije i prioritizacije, timovi se lako izgube u šumu podataka.

Forenzička analiza je dodatno otežana zbog kratkog životnog vijeka nekih resursa. U cloud i kontejnerskim okruženjima instance servisa može nestati veoma brzo nakon incidenta, čime se gube potencijalno važni tragovi ako nijesu na vrijeme sačuvani. Zbog toga je unaprijed pripremljeno prikupljanje relevantnih podataka ključno za kvalitetnu istragu. U suprotnom, organizacija zna da je incident postojao, ali ne može tačno utvrditi kako se odigrao.

Održavanje bezbjednosti zato zahtijeva rutinu, alate, procedure i odgovorne ljude. To nije posao koji se obavlja povremeno, već trajna aktivnost koja prati cijeli životni ciklus distribuiranog sistema. Samo takav pristup može pružiti stvarnu otpornost na promjene i incidente.

7. NAJBOLJE PRAKSE I PREPORUKE ZA UNAPREĐENJE BEZBJEDNOSTI

7.1. Ugradnja bezbjednosti od faze projektovanja sistema

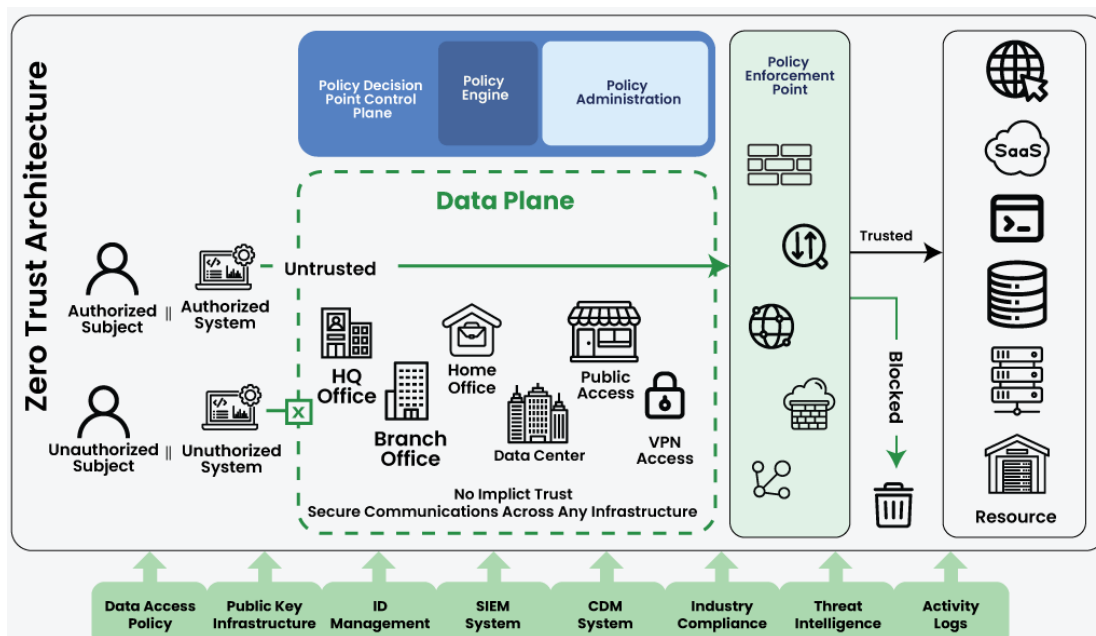
Jedna od najvažnijih preporuka za izgradnju sigurnih distribuiranih sistema jeste da se bezbjednost uključi još u fazi projektovanja, a ne tek nakon implementacije. Kada se zaštita uvodi naknadno, najčešće se svodi na dodavanje parcijalnih mehanizama oko već postojeće arhitekture, što rijetko daje optimalne rezultate. Nasuprot tome, ako se rizici, identiteti, tokovi podataka, privilegije i granice povjerenja razmotre od samog početka, sistem se može oblikovati na mnogo otporniji način.

Ovakav pristup zahtijeva da se već u ranoj fazi razmotri koje informacije su osjetljive, koji servisi komuniciraju, kako će se provjeravati identiteti, gdje će se čuvati tajne i kako će se pratiti aktivnosti. Kada su ta pitanja jasno postavljena, lakše je donijeti ispravne tehničke i organizacione odluke. Takođe se smanjuje potreba za kasnijim skupim i rizičnim izmjenama.

Projektovanje bezbjednosti od početka ne znači usporavanje razvoja, već suprotno. Dobro osmišljena arhitektura smanjuje broj kasnijih hitnih ispravki, incidenta i improvizacija. Time se dugoročno štede i vrijeme i resursi, a sistem postaje predvidiviji i lakši za održavanje.

7.2. Primjena principa najmanjih privilegija i nultog povjerenja

Princip najmanjih privilegija podrazumijeva da svaki korisnik, servis ili proces dobija samo onaj pristup koji mu je stvarno potreban za izvršavanje zadatka. Ovaj princip možda zvuči jednostavno, ali je u praksi jedan od najmoćnijih načina smanjenja bezbjednosnog rizika. Ako kompromitovani entitet nema široka prava, šteta se prirodno ograničava.



Slika 6 - Arhitektura nultog povjerenja

„Model nultog povjerenja ide korak dalje i polazi od pretpostavke da nijedan zahtjev ne treba automatski smatrati bezbjednim, bez obzira na to da li dolazi spolja ili iz interne mreže. Svaki pristup mora biti provjeren, autorizovan i procijenjen u konkretnom kontekstu. Ovakav pristup je posebno prikladan za moderne distribuirane sisteme, gdje granice između “unutrašnjeg” i “spoljašnjeg” okruženja više nijesu jasne kao ranije“ [1].

Primjena ovih principa zahtijeva disciplinovano upravljanje identitetom, detaljne politike pristupa, segmentaciju mreže i stalno praćenje aktivnosti. Iako može zahtijevati dodatni trud u početku, dugoročno vodi ka mnogo sigurnijem i preglednijem sistemu. Organizacije koje dosljedno primjenjuju ove principe lakše kontrolišu rizik i brže uočavaju odstupanja.

7.3. Redovno ažuriranje, testiranje i procjena rizika

Ni jedan distribuirani sistem ne ostaje bezbjedan samo zato što je jednom dobro podešen. Softver stari, pojavljuju se nove ranjivosti, mijenjaju se biblioteke, protokoli i načini napada. Zbog toga je redovno ažuriranje jedan od osnovnih uslova očuvanja bezbjednosti. To se odnosi na operativne sisteme, aplikacione komponente, biblioteke, kontejnerske slike, mrežne uređaje i sve druge elemente infrastrukture.

Testiranje bezbjednosti mora biti kontinuirano i raznovrsno. Potrebno je provjeravati konfiguracije, skenirati poznate ranjivosti, testirati kontrole pristupa, analizirati API interfejse i procjenjivati otpornost sistema na različite oblike zloupotrebe. U ozbiljnim okruženjima ovo se kombinuje sa redovnim procjenama rizika, koje pomažu da se zaštitne mjere usmjere tamo gdje su najpotrebnije.

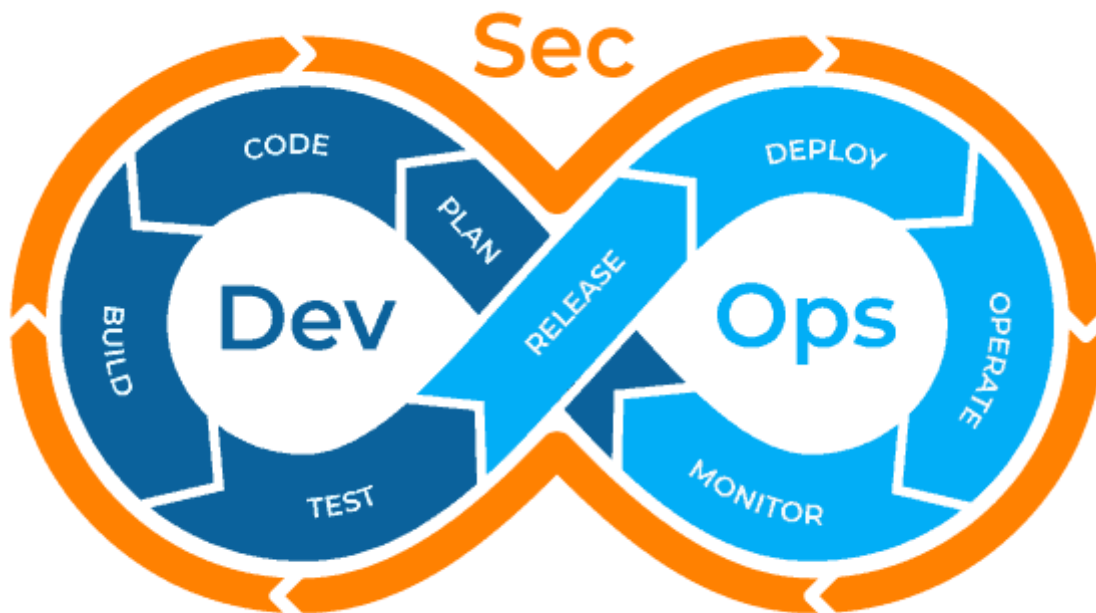
Procjena rizika je važna zato što nijedna organizacija nema beskonačne resurse. Potrebno je znati koji podaci i servisi imaju najveći značaj, gdje su najosjetljivije tačke i koji incidenti bi imali najveće posljedice. Tek na osnovu toga može se donijeti razumna odluka o tome šta se štiti najstrože i kojim redoslijedom se unapređuju kontrole.

7.4. Automatizacija bezbjednosnih provjera i DevSecOps pristup

Kako distribuirani sistemi postaju složeniji i dinamičniji, ručno sprovođenje bezbjednosnih provjera postaje nedovoljno. Zato je automatizacija jedan od ključnih pravaca unapređenja. Automatizovane provjere mogu rano otkriti ranjive pakete, pogrešne konfiguracije, nebezbedne zavisnosti, preširoke privilegije i odstupanja od definisanih pravila. Time se smanjuje vjerovatnoća da ozbiljan problem dospije u produkciono okruženje.

DevSecOps pristup podrazumijeva uključivanje bezbjednosti u tok razvoja, testiranja i isporuke softvera.

Umjesto da se bezbjednost posmatra kao odvojena i kasna faza, ona se integriše u automatizovane procese. To znači da se sigurnosne provjere izvršavaju već tokom razvoja i implementacije, čime se problemi otkrivaju ranije i rješavaju jeftinije.



Slika 7 - Prikaz životnog ciklusa razvoja softvera u obliku petlje, sa istaknutim fazama bezbjednosnih provjera

Ipak, automatizacija nije zamjena za razumijevanje sistema. Alati mogu pomoći, ali ne mogu sami zamijeniti odgovornost, arhitektonsko razmišljanje i procjenu poslovnog konteksta. Najbolji rezultati postižu se kada automatizacija podržava dobro definisane procese i kada timovi razumiju zašto se određena pravila sprovode.

7.5. Edukacija korisnika i razvoj bezbjednosne kulture

Na kraju, nijedan tehnički sistem ne može biti u potpunosti siguran ako ljudi koji ga koriste i održavaju nijesu dovoljno svjesni rizika. Edukacija korisnika i razvoj bezbjednosne kulture zato predstavljaju jedan od najvažnijih dugoročnih elemenata zaštite. Korisnik koji prepoznaje sumnjiv zahtjev, administrator koji razumije značaj segmentacije i programer koji zna kako se sigurno rukuje tajnama doprinose bezbjednosti mnogo više nego što se često pretpostavlja.

Bezbjednosna kultura znači da zaštita nije samo zadatak jednog tima, već zajednička vrijednost organizacije. To ne podrazumijeva stalno širenje straha, već razvoj navika, procedura i razumijevanja zašto su određena pravila važna. Kada korisnici i tehnički timovi shvataju posljedice loših praksi, lakše prihvataju i mjere zaštite koje bi im inače djelovale kao nepotrebna komplikacija.

Edukacija mora biti stalna i prilagođena ulozi onih kojima je namijenjena. Administratorima su potrebna znanja o konfiguraciji i incidentima, programerima o sigurnom razvoju, a krajnjim korisnicima o odgovornom ponašanju i prepoznavanju pokušaja prevare. Samo takvim višeslojnim pristupom moguće je smanjiti uticaj ljudskog faktora kao izvora bezbjednosnih incidenata.

ZAKLJUČAK

Bezbjednost u distribuiranim sistemima predstavlja jedno od najvažnijih i najsloženijih pitanja savremenog informacionog društva. Kako digitalne usluge postaju sve rasprostranjenije, a infrastruktura sve više raspoređena između različitih servisa, mreža, cloud okruženja i uređaja, raste i potreba za dosljednim, višeslojnim i arhitektonski promišljenim pristupom zaštiti. Distribuirani sistemi nude velike prednosti u pogledu skalabilnosti, fleksibilnosti i dostupnosti, ali te iste osobine istovremeno proširuju površinu napada i povećavaju broj mogućih ranjivosti.

U radu je pokazano da bezbjednost u distribuiranim sistemima nije moguće ostvariti samo jednim mehanizmom ili jednom tehnologijom. Potrebno je istovremeno voditi računa o povjerljivosti, integritetu i dostupnosti, ali i o upravljanju identitetima, kontroli pristupa, zaštiti komunikacije, evidenciji aktivnosti i otpornosti na incidente. Prijetnje dolaze iz različitih izvora, od mrežnih napada i krađe identiteta, preko napada na podatke i API interfejsa, pa sve do grešaka konfiguracije i ljudskog faktora. Upravo zbog toga zaštita mora biti sveobuhvatna i prilagođena stvarnoj prirodi sistema.

Posebno je važno istaći da savremene arhitekture, kao što su cloud okruženja, mikroservisi, kontejnerske platforme i IoT sistemi, zahtijevaju dodatni nivo pažnje. U takvim okruženjima više nije dovoljno osloniti se na klasičnu zaštitu mrežnog perimetra. Potrebna je detaljna provjera svakog identiteta, svake komunikacije i svakog prava pristupa. Takođe je neophodno osigurati stalni nadzor, automatizovane provjere i spremnost na odgovor u slučaju incidenta.

Na osnovu svega navedenog može se zaključiti da je bezbjednost distribuiranih sistema trajni proces, a ne jednokratni zadatak. Ona zahtijeva kombinaciju tehničkih rješenja, organizacionih mjera, stručnog znanja i razvijene bezbjednosne kulture. Samo sistem koji je projektovan sa bezbjednošću u svojoj osnovi, koji se redovno provjerava i u kojem su odgovornosti jasno definisane može dugoročno očuvati funkcionalnost, povjerenje korisnika i otpornost na sve složenije prijetnje savremenog digitalnog okruženja.

POPIS SLIKA

Slika 1 - Dijagram koji prikazuje više servera, baza podataka i klijenata povezanih mrežom.....	2
Slika 2 - Prikaz najčešćih ulaznih tačaka i vektora napada u distribuiranom okruženju – od mrežnih veza i API interfejsa do kompromitovanih identiteta i ranjivih servisa.....	6
Slika 3 - Proces kriptovanja podataka.....	14
Slika 4 - Autentifikacija korisnika pomoću SSO-a.....	16
Slika 5 - Mikroservisna arhitektura.....	20
Slika 6 - Arhitektura nultog povjerenja	25
Slika 7 - Prikaz životnog ciklusa razvoja softvera u obliku petlje, sa istaknutim fazama bezbjednosnih provjera	27

CITATNI IZVORI

- [1] A. S. Tanenbaum i M. van Steen, Distributed Systems: Principles and Paradigms, Upper Saddle River, NJ: Pearson Prentice Hall, 2007.
- [2] G. Coulouris, J. Dollimore, T. Kindberg i G. Blair, Distributed Systems: Concepts and Design, London: Addison-Wesley, 2011.
- [3] J. F. Kurose i K. W. Ross, Computer Networking: A Top-Down Approach, New York: Pearson, 2021.